

Miasma / Hades — Protection & Detection Layer

Repo-open execution: the vector that bypasses dependency scanning entirely
iHBV | 22 Aug 2026 | Ref: ThreatLocker, 9 Jun 2026 — Azure/durabledtask, 73 Microsoft repos disabled

1. Why existing tooling misses this

Every dependency scanner — depSNORT included — answers one question: *what happens when I INSTALL these dependencies?* Miasma skips installation entirely. Its payload runs the moment a developer **opens the repository** in an editor or AI coding agent, driven by checked-in configuration: an obfuscated setup.js, a VS Code workspace tasks file, and agent settings carrying LLM hooks for Claude and Gemini. No package is installed, so no dependency scanner is ever consulted.

I verified this against our own tool: depSNORT has **zero** coverage of .vscode/, .devcontainer/, agent hook files or .envrc. That is not a defect — it is outside its threat model by design. Closing it requires a different control, not a better dependency scan.

The second-order risk is workflow-specific and worth stating plainly: a purple-team practice that clones untrusted repositories for analysis, then opens them in an agent-enabled editor, is **exactly the targeted population**. The campaign also actively hunts StepSecurity Harden-Runner containers and domains to evade sandboxing.

2. Layer 1 — Protection (workflow, deploy today)

Ordered by leverage. The first item alone defeats the observed execution path.

#	Control	Implementation
1	Never open an unreviewed clone in an agent-enabled editor	Use a quarantine path; triage first (Layer 2); only then open
2	Disable automatic tasks globally	VS Code user settings: task.allowAutomaticTasks = "off"
3	Keep Workspace Trust ON, and never let a workspace disable it	workspace.trust.enabled = true; untrustedFiles = "newWindow"
4	Blind-clone for analysis	git clone --no-checkout, or --filter=blob:none, and scan before checkout
5	Analyse in a container, not on the host	devcontainer initializeCommand runs on the HOST — containers alone are NOT sufficient
6	Pin agent config to a trusted source	Ignore in-repo .claude/.gemini/.cursor/.mcp.json for untrusted repos
7	Control git hooks centrally	git config --global core.hooksPath <trusted dir>

Item 5 deserves emphasis: initializeCommand in a devcontainer executes on the **host** before the container is created. "I opened it in a devcontainer" is not containment.

3. Layer 2 — Detection

3a. iHBV RepoGuard — pre-open triage (new, delivered)

A read-only scanner for the on-open execution surface. It never executes, installs or imports from the target; unreadable files are disclosed rather than assumed clean. It grades a file by combining three signals: the file is an on-open surface, it carries an auto-run trigger, and it shows payload characteristics.

```
python3 ihbv-repoguard.py /path/to/fresh-clone # human output
python3 ihbv-repoguard.py /path/to/fresh-clone --json # pipeline output
exit 0 = nothing found | 1 = findings | 2 = usage error
```

Detects: VS Code runOn: folderOpen, devcontainer initializeCommand/lifecycle commands, agent hooks bound to automatic events (SessionStart / PreToolUse / PostToolUse), MCP server definitions that spawn processes, .envrc, checked-in git hooks, workspace attempts to disable Workspace Trust or redirect tool binaries — plus obfuscation (long base64 / hex blobs), dynamic eval, process execution and network fetch, and the campaign IOCs below.

Validation. Against a reconstruction of the Miasma shape it flagged all four vectors CRITICAL (folderOpen task, Claude SessionStart hook, host-level initializeCommand, obfuscated setup.js). Against real repositories: meshclaw and eyeExtend-Connect clean; atomic-red-team produced **2 findings across 3,642 files** — its genuine devcontainer lifecycle config and one attack script — both correctly graded HIGH rather than CRITICAL. Severity separation between "this repo configures execution on open" and "this repo looks like Miasma" holds.

3b. depSNORT IOC ledger — package half (works today, no code change)

The campaign also poisoned published durable task releases, which is in depSNORT's model. The delivered ledger feeds its existing operator-IOC axis (VC-003):

```
depsnort scan -ioc ihbv-ioc-miasma-hades.json <target>

validated: durabletask==1.4.2 -> VC-003 BLOCK
"listed in the operator IOC ledger (category malware; ref iHBV-IOC-MIASMA-01)"
```

Covers the three poisoned versions as CRITICAL plus a version-agnostic HIGH on the package, since the upstream repository itself was compromised. Verify sdists/wheels SHA256 out-of-band against the published hashes before trusting any release.

3c. Hunt — host and network

Feed these to the existing detection stack (KQL corpus / MARLEY):

Type	Indicator
Network	check.git-service[.]com t.m-kosche[.]com 160.119.64.3
Host	/tmp/managed.pyz /tmp/updater.py ~/.cache/.sys-update-check(-k8s)
Host	/usr/bin/pgmonitor.py ~/.local/bin/pgmonitor.py postgresql-monitor.service
Behaviour	python3 /tmp/managed.pyz new systemd unit from a user session hourly beacon loop
GitHub	commit search: thebeautifulmarchoftime / thebeautifulsnadsoftime / firedalazer
GitHub	repo marker "Hades * The End for the Damned"; adjective+noun exfil repos (stygian-cerberus, etc.)
Destructive	token name IfYouYankThisTokenItWillNukeTheComputerOfTheOwnerFully — rejection triggers rm -rf ~/

Note the destructive branch: if the planted token is revoked, the payload deletes the user's home and Documents directories. Prefer isolation and imaging over naive token revocation on a suspected-infected host.

4. Recommended next step — fold this into depSNORT

RepoGuard is deliberately standalone so it is usable today, but the durable home for this is a new depSNORT check axis — provisionally **VC-012, repo-open execution surface** — reusing the existing capability scanner (network / exec / cradle / obfuscation markers) that already backs VC-002. That would put on-open execution in the same verdict, gate and EPSS-ranked report as everything else, rather than a second tool to remember to run. Scoped as one increment: detector + gate class + regression corpus, with the Miasma reconstruction and atomic-red-team as fixtures.

Destiny is all.